

OPERATION BLACK FORGE

Executive Summary — CTF 2 Penetration Test

Student	Daniyal Ahmed — C11/26/EHIT/17331
Course	Offensive Security Operations II — CIP-A105
Assessment	CTF 2 — Operation Black Forge
Date	22 September 2026
Classification	Training Use Only

★ ENGAGEMENT OUTCOME: FULL SYSTEM COMPROMISE ★

1. Engagement Overview

Operation Black Forge was an authorised, black-box penetration test conducted against OPFOR-02 (192.168.233.130) — an intermediate-level intentionally vulnerable Linux server running an OpenEMR 4.1.0 healthcare Electronic Medical Records application. The engagement was conducted entirely within an isolated VirtualBox Host-Only network with no connectivity to production systems or the public internet.

The assessment was completed in a single session on 22 September 2026. Total system compromise — from unauthenticated network access to full root-level administrative control — was achieved through a four-stage attack chain.

2. Attack Chain Summary

- **Stage 1 — SQL Injection:** Web application enumeration discovered an OpenEMR 4.1.0 instance at /openemr/. Research identified a known SQL injection vulnerability (EDB-49742) in the login endpoint.
- **Stage 2 — Credential Harvest:** sqlmap was used to extract the openemr.users database table. Administrator and medical user credentials were recovered and the MD5 password hashes cracked.
- **Stage 3 — PHP Shell Injection:** Authenticated as administrator, the built-in file editor was used to inject a PHP reverse shell payload into config.php, establishing a shell as the apache web server user.
- **Stage 4 — Privilege Escalation:** A SUID binary was identified that calls an external command without an absolute path. PATH environment variable manipulation caused the binary to execute a malicious script as root, achieving full system compromise.

3. Risk Summary

Severity	Count	Primary Finding
Critical	3	OpenEMR SQLi, PHP File Editor RCE, SUID Priv Esc
High	2	Weak Credentials, Outdated ProFTPD
Medium	1	Directory Listing / Information Disclosure

4. Immediate Recommended Actions

- Upgrade OpenEMR immediately to eliminate the SQL injection vulnerability.
- Change all application passwords to strong, unique values and migrate from MD5 hashing.
- Disable or restrict the OpenEMR admin file editor feature.
- Remove unnecessary SUID bits from system binaries and update OS/kernel.
- Disable ProFTPD if not operationally required; upgrade if retained.